INFORMATIONSBLATT

IB01 · PKI und TLS-Zertifikate

LF10b · LS07 – HTTPS mit Let's Encrypt automatisieren · IB01 – PKI und TLS · IT-3B · 2025/2026

1 · Public Key Infrastructure (PKI)

📖 **PKI – Public Key Infrastructure**
Eine **PKI** ist ein System aus Richtlinien, Prozessen und Technologien zur Verwaltung digitaler Zertifikate und kryptografischer Schlüssel. Herzstück ist die **Certificate Authority (CA)** – eine vertrauenswürdige Stelle, die Zertifikate ausstellt und digital signiert.

Begriff	Bedeutung
Certificate Authority (CA)	Vertrauenswürdige Stelle, die Zertifikate signiert (Let's Encrypt, DigiCert, D-TRUST)
Root-CA	Oberste CA, deren Zertifikat im Browser/OS vorinstalliert ist
Intermediate-CA	Zwischeninstanz zwischen Root-CA und Endnutzer-Zertifikat
Zertifikat	Digitales Dokument: enthält Domain, Public Key, Aussteller, Gültigkeit, Signatur der CA
Vertrauenskette (Chain of Trust)	Browser vertraut Root-CA → Root-CA hat das Intermediate-Zertifikat signiert → Intermediate-CA signiert Ihr Zertifikat

2 · Self-Signed vs. CA-signierte Zertifikate

Merkmal	Self-Signed (LS02)	CA-signiert (Let's Encrypt)
Erstellt von	Server selbst (openssl req)	Certbot + Let's Encrypt CA
Vertrauen	Browser zeigt Warnung	Browser vertraut automatisch
Kosten	Kostenlos	Kostenlos (Let's Encrypt)
Gültigkeit	Manuell wählbar (z.B. 365 Tage)	90 Tage (automatisch erneuert)
Geeignet für	Interner Test, Schulumgebung	Öffentliche Server, Produktion
Erneuerung	Manuell	Automatisch via Certbot

📖 **Warum 90 Tage Gültigkeit?**
Let's Encrypt stellt Zertifikate bewusst nur für **90 Tage** aus:

- **Automatisierung fördern:** Kurze Laufzeiten erzwingen automatische Prozesse – manuelles Erneuern ist nicht praktikabel

- **Kompromittierung begrenzen:** Ein gestohlener Private Key ist nur 90 Tage nutzbar
- **Revocation weniger wichtig:** Wer auf automatische Erneuerung setzt, kann Zertifikate einfach durch neue ersetzen

Ausblick: Let's Encrypt verkürzt die Laufzeit schrittweise weiter – ab 10.02.2027 auf 64 Tage, ab 16.02.2028 auf 45 Tage (Stand 2026). Automatische Erneuerung wird damit noch wichtiger.

3 · Let's Encrypt

📖 **Let's Encrypt**
Let's Encrypt ist eine gemeinnützige, kostenlose CA, betrieben von der Internet Security Research Group (ISRG). Ziel: HTTPS für alle Webserver kostenlos und automatisierbar machen. Let's Encrypt nutzt das **ACME-Protokoll** zur automatischen Domain-Validierung.

Eigenschaft	Details
Zertifikat-Typ	Domain Validation (DV) – beweist nur Domain-Kontrolle
Gültigkeitsdauer	90 Tage
Kosten	Kostenlos
Rate Limits	Max. 50 Zertifikate pro Domain/Woche (Staging-Umgebung: deutlich höhere Limits – ideal zum Testen)
Vertrauen	Von allen modernen Browsern vertraut (Root-Zertifikat in allen OS/Browsern)
Automatisierung	ACME-Protokoll + Certbot-Client

4 · Die vier Zertifikat-Dateien

Nach erfolgreicher Certbot-Ausführung liegen die Dateien in `/etc/letsencrypt/live/ihre-domain.de/`:

Datei	Inhalt	Verwendung in Apache
`cert.pem`	Ihr Zertifikat (nur Endnutzer-Cert)	SSLCertificateFile
`privkey.pem`	Ihr privater Schlüssel (geheim!)	SSLCertificateKeyFile
`chain.pem`	Intermediate-Zertifikate der CA	(in fullchain enthalten)
fullchain.pem	cert.pem + chain.pem kombiniert	**SSLCertificateFile (empfohlen)**

⚠️ **privkey.pem streng geheim!**
Der Private Key darf niemals übertragen, gesichert oder geteilt werden. Certbot setzt die Berechtigungen auf `600` (nur Root lesbar). Niemals in Backups auf externen Diensten speichern!

5 · HSTS – HTTP Strict Transport Security

📖 **HSTS**
HSTS ist ein HTTP-Sicherheits-Header, der Browser anweist, für eine bestimmte Zeit **ausschließlich HTTPS** für diese Domain zu verwenden – auch wenn der Benutzer `http://` eingibt.

	HTTP→HTTPS Redirect (Apache)	HSTS
Wie	Server sendet 301 Redirect	Browser ignoriert HTTP komplett
Aufruf mit http://	HTTP-Anfrage geht bei *jedem* Aufruf erst unverschlüsselt raus	Nur der allererste Besuch läuft noch über HTTP (außer bei Preload) – danach sendet der Browser direkt HTTPS
SSL-Stripping Angriff	Möglich (Angreifer fängt HTTP ab)	Nach dem ersten Besuch nicht mehr möglich (Browser sendet kein HTTP); mit Preload-Liste von Anfang an geschützt
Konfigurationsort	Apache VHost Port 80	Apache VHost Port 443 (Header)

HSTS-Header in Apache aktivieren

```
<VirtualHost *:443>
    # ... bestehende Konfiguration ...
    Header always set Strict-Transport-Security "max-age=31536000; includeSubDomains"
</VirtualHost>
```

Parameter	Wert	Bedeutung
max-age	31536000	Browser merkt sich HSTS für 1 Jahr (in Sekunden)
includeSubDomains	optional	HSTS gilt auch für alle Subdomains (www., mail., ...)
preload	optional (fortgeschritten)	Domain in Browser-HSTS-Preload-Liste eintragen